Trabajos de investigación SSI 2026/27

Enunciado, temas, entregables, rúbrica y normas de uso de IA generativa

Trabajos de investigación SSI 2026/27

1. Objetivo y organización
2. Temas propuestos
   - Tema A. Pentesting autónomo con agentes de IA
   - Tema B. Automatización de la respuesta a incidentes: SOAR, XDR,agentes SOC
   - Tema C. Malware moderno y uso de IA/ML: ataque y detección
   - Tema D. Seguridad de los sistemas de IA: ataques a LLM y modelos de ML
   - Tema E. Seguridad en la nube, contenedores y Kubernetes
   - Tema F. Seguridad de IoT, OT e infraestructuras críticas
3. Contenido de los entregables
   - 3.1. Informe escrito (15-20 páginas)
   - 3.2. Presentación en el aula (20-25 minutos)
   - 3.3. Cuestionario / examen de repaso (10-12 preguntas)
4. Rúbrica de evaluación
5. Uso de IA generativa en esta actividad
   - Qué se permite
   - Principios
   - Malas prácticas (penalizadas en el criterio de autoría y uso de IA)
   - Recomendaciones
   - Declaración obligatoria de uso de IA
6. Declaración de uso de IA

---

1. Objetivo y organización

Esta actividad complementa los contenidos del curso con aspectos **novedosos y recientes** de la ciberseguridad que no se cubren en las clases y prácticas habituales.

- Cada equipo investiga un tema, lo documenta, lo explica al resto de la clase y prepara material de repaso.
- Conviene que todos los miembros del equipo aporten de forma equitativa al informe escrito y a la exposición.

Aspecto	Condiciones
Equipos	4-5 personas
Informe escrito	15-20 páginas
Presentación en el aula	20-25 minutos, planteada como una **clase** para los compañeros
Cuestionario / examen de repaso	10-12 preguntas, con solucionario justificado

> **Fechas de entrega:** *por definir*

2. Temas propuestos

Tema A. Pentesting autónomo con agentes de IA

Enfoque: cómo los LLM y los agentes (p. ej. PentAGI, PentestGPT, frameworks de agentes con herramientas como Nmap o Metasploit, sistemas que compiten en CTF o bug bounty) automatizan reconocimiento, explotación y reporte.

- Arquitecturas de agentes (planificación, memoria, uso de herramientas, MCP).
- Resultados en benchmarks y competiciones, y sus límites reales.
- Riesgos: alucinaciones, alcance fuera de control, responsabilidad legal.
- Demo opcional (a valorar por cada equipo): agente sencillo contra un laboratorio (DVWA, Metasploitable).

Tema B. Automatización de la respuesta a incidentes: SOAR, XDR,agentes SOC

Enfoque: cómo se automatizan triaje, enriquecimiento y contención, y el papel emergente de los «analistas SOC con IA».

- SIEM vs. SOAR vs. XDR; playbooks automatizados.
- Herramientas abiertas disponibles: Shuffle, TheHive/Cortex, Wazuh.
- Ejemplos de escenarios tipo: phishing, credenciales comprometidas, aislamiento de endpoints.
- Límites: falsos positivos, automatizar sin romper el negocio, supervisión humana.
- Automatización de la respuesta con agentes de IA

Tema C. Malware moderno y uso de IA/ML: ataque y detección

Enfoque: malware polimórfico y metamórfico generado o asistido por IA, evasión de EDR, *living off the land*, ransomware-as-a-service y, en paralelo, los modelos de ML para detección.

- Taxonomía del malware actual y sus técnicas de evasión, vinculación con técnicas de MITRE ATT&CK.
- Ejemplos documentados de uso de LLM por grupos de amenaza.
- Detección con ML: características estáticas/dinámicas, clasificadores, ataques adversariales contra ellos.
- Demo opcional (a valorar por cada equipo): análisis de una muestra en sandbox (con material controlado).
    - Como alternativa, estudio de muestras preanalizadas en JoeSandbox, ANY.run.

Tema D. Seguridad de los sistemas de IA: ataques a LLM y modelos de ML

Enfoque: la IA como superficie de ataque (se centra en **atacar a los modelos**).

- *Prompt injection* (directa e indirecta), jailbreaks, fuga de datos.
- Envenenamiento de datos, extracción e inversión de modelos, ataques adversariales (Adversarial ML).

- Riesgos en agentes y ecosistemas de herramientas (p. ej. servidores MCP, plugins).
- Marcos de referencia: OWASP Top 10 para LLM, MITRE ATLAS, NIST AI RMF.

Tema E. Seguridad en la nube, contenedores y Kubernetes

Enfoque: superficie de ataque y errores de configuración en infraestructuras cloud-native, con el modelo de responsabilidad compartida como hilo conductor.

- Riesgos típicos: buckets y roles IAM mal configurados, secretos expuestos, escape de contenedores, *misconfigurations* en Kubernetes.
- Casos reales de brechas por configuración en la nube.
- Herramientas: Trivy, Falco, kube-bench, Prowler, ScoutSuite; conceptos de CSPM y CNAPP.
- Marcos de referencia: CIS Benchmarks, MITRE ATT&CK para Cloud/Containers, OWASP Kubernetes Top 10.
- Demo opcional (a valorar por cada equipo): cluster local (kind/minikube) con configuración vulnerable, escaneo y endurecimiento.

Tema F. Seguridad de IoT, OT e infraestructuras críticas

Enfoque: sistemas ciberfísicos donde un ataque tiene consecuencias físicas, con ciclos de vida largos y parcheo difícil.

- Protocolos y arquitectura: Modbus, DNP3, OPC UA, modelo Purdue, segmentación IT/OT.
- Incidentes emblemáticos: Stuxnet, red eléctrica ucraniana, Colonial Pipeline, amenazas actuales a dispositivos expuestos.
- Seguridad de firmware y dispositivos IoT: análisis de firmware, credenciales por defecto, botnets (Mirai y sucesoras).
- Normativa y estándares: IEC 62443, NIS2, seguridad por diseño.
- Demo opcional (a valorar por cada equipo): análisis de firmware con Binwalk/Ghidra o simulación de entorno ICS (p. ej. GRFICSv2, Conpot) con captura y análisis de tráfico.

---

3. Contenido de los entregables

3.1. Informe escrito (15-20 páginas)

Estructura orientativa (a adaptar en cada caso):

1. **Introducción y objetivos:** qué se estudia y por qué es relevante hoy.
2. **Fundamentos y estado del arte:** conceptos, arquitecturas y técnicas, con énfasis en lo reciente (últimos 2-3 años).
3. **Casos reales (si procede):** incidentes, campañas o productos documentados, analizados con rigor.
4. **Componente práctico (si procede):** laboratorio o demostración **documentado y reproducible** (entorno, pasos, capturas, resultados).
5. **Defensa, riesgos y mitigaciones (si procede).**
6. **Aspectos legales y éticos (si procede).**

7. **Análisis crítico y conclusiones:** límites, tendencias, valoración propia del grupo.
8. **Bibliografía:** fuentes primarias y fiables (papers, informes de fabricantes/CERT, estándares, CVE, documentación oficial) en formato de citación consistente.
9. **Declaración de uso de IA** (ver apartado 5).

Requisitos: estructura lógica, redacción clara, figuras legibles y referenciadas en el texto, y extensión dentro del rango pedido.

3.2. Presentación en el aula (20-25 minutos)

- Debe funcionar como **una clase**: objetivos claros, progresión lógica, ejemplos que faciliten la comprensión y resumen final.
- Incluir una **demo o ejemplo práctico** bien integrado (se recomienda tener un vídeo de respaldo por si falla el directo).
- Diapositivas limpias, con esquemas propios y cantiadad de texto adecuada; no leer las diapositivas.
- Participación **equilibrada** de todos los miembros.
- Respetar el tiempo y reservar unos minutos para preguntas.

3.3. Cuestionario / examen de repaso (10-12 preguntas)

- Debe cubrir **todos los bloques clave** del tema, con peso proporcional.
- Enunciados inequívocos, distractores plausibles y **una única respuesta correcta defendible**.
- Mezcla de niveles: recuerdo, comprensión y **aplicación** (casos, análisis de logs, escenarios).
- **Solucionario** con una breve justificación de por qué cada opción es correcta o incorrecta.
- Formato claro y listo para usar (p. ej. fichero Markdown).

---

4. Rúbrica de evaluación

`<pendiente>`

---

5. Uso de IA generativa en esta actividad

Qué se permite

Se permite el uso de herramientas de IA generativa como **apoyo** para:

- Conceptualizar y delimitar el enfoque del trabajo.
- Estructurar los entregables (índice, guion de la presentación, esquema del cuestionario).
- Mejorar la redacción (claridad, estilo, corrección).
- Generar contenido de apoyo: gráficas, esquemas y diagramas.

Principios

1. **La IA es una herramienta, no la autora.** Los entregables son producto del equipo, que responde íntegramente de su contenido, su exactitud y su calidad.
2. **Todo debe ser revisado y validado por el grupo.** Cada miembro debe poder explicar y defender cualquier parte del trabajo, incluidas las generadas con ayuda de IA.
3. **Uso con criterio, no indiscriminado.** El valor del trabajo está en la investigación, el análisis y las aportaciones propias del equipo.

Malas prácticas (penalizadas en el criterio de autoría y uso de IA)

- **Bibliografía inexistente, incompleta o no relacionada** con el contenido, o no comprobada por el equipo. Toda referencia debe haberse localizado y consultado, asegurando que es pertinente para el trabajo.
- **Figuras y diagramas ilegibles** o sin relación con el contenido que acompañan.
- **Indicios de copy-paste:** texto pegado sin elaborar, con estilo heterogéneo o sin integrar.
- **Relleno:** texto genérico, redundante o sin aportes relevantes al tema.

Recomendaciones

- Contrastar los datos técnicos con fuentes primarias (documentación oficial, estándares, papers, ...).
- Comprobar que cada figura se lee bien, está referenciada en el texto y aporta algo.

Declaración obligatoria de uso de IA

El informe debe incluir, tras la bibliografía, un apartado titulado **«Declaración de uso de IA»** con una tabla como esta:

Herramienta (y versión/modelo)	**Tarea en la que se usó**	**Partes del trabajo afectadas**	**Cómo se usó/verificó el resultado**
Ej.: ChatGPT / Claude / Copilot	*Ej.: propuesta de índice; revisión de redacción; diagrama de arquitectura*	*Ej.: apartado 2; figura 3*	*Ej.: contraste con documentación oficial; referencias localizadas una a una*

(ver ejemplo aplicado a este documento en la sección 6.)

- Si no se usó IA, debe indicarse expresamente: «No se ha utilizado IA generativa».
- La declaración es **colectiva** y aplica a los **tres entregables** (informe, presentación y cuestionario).
- Omitirla, o que sea incompleta o inexacta, se considerará falta de transparencia y afectará a la calificación del criterio de autoría.

6. Declaración de uso de IA

Herramienta (y versión/modelo)	**Tarea en la que se usó**	**Partes del trabajo afectadas**	**Cómo se usó/verificó el resultado**
Claude (versión gratuita)	*esbozo de la estructura del documento*		*reajuste de secciones y contenidos*
Claude (versión gratuita)	*listado previo de propuestas de temas* (brainstorming)	*sección 2*	*priorización y selección manual de la lista final de 6 temas, reescritura de las descripciones e indicaciones de cada tema seleccionado*
Claude (versión gratuita)	*esbozo inicial de la rúbrica de evalaución*	*sección 4*	*simplificación profunda de la rúbrica propuesta y reescritura de los criterios y ponderaciones*